

CAPÍTULO 8 · RESUMO DE ESTUDO

Auditoria de Gestão, Governança de TI, Ética e Comunicação

Como a TI deve ser governada (Egit, alinhada ao Cobit 2019), a classificação e priorização de ativos de informação, a auditoria de gestão em TI baseada em riscos, os princípios éticos que sustentam a credibilidade da auditoria e as boas práticas de comunicação de resultados à alta gestão — condensado para revisão antes da prova.

Curso Educação a Distância · Segurança e Auditoria de Sistemas de Informação

Base Cobit 2019 (Isaca), ABNT NBR ISO/IEC 38500, IPPF/IIA, Itaf, Iesba, Nist CSF 2.0, Nistir 8286, TCU

1. Governança & ativos

2. Auditoria de gestão em TI

3. Ética & dilemas éticos

4. Comunicação eficaz

Termos-chave

Revisão rápida

01

Governança de TI e classificação de ativos

Governança de TI é parte da governança corporativa: os mecanismos pelos quais a empresa direciona e controla o uso da informação e da tecnologia para gerar valor e gerenciar riscos.

No Cobit 2019, essa visão é estruturada pelo conceito de **Egit** (enterprise governance of information and technology). A Egit é exercida pelo **conselho de administração e alta gestão** — que definem princípios, estruturas e processos de governança (políticas, apetite de risco, estruturas decisórias, monitoramento) — enquanto a **gestão de TI** executa e operacionaliza essas diretrizes no nível operacional.

A ABNT NBR ISO/IEC 38500 reforça essa visão com princípios de **responsabilidade, estratégia, aquisição, desempenho, conformidade e comportamento humano**. Para o setor público, o TCU define governança organizacional como o conjunto de mecanismos de liderança, estratégia e controle para avaliar, direcionar e monitorar a gestão.

Classificação de ativos de informação – processo típico

- 1 **Identificar** as informações que suportam linhas de negócio e processos críticos.
- 2 **Definir critérios** de classificação com base em requisitos legais, regulatórios e de negócio.
- 3 **Avaliar impactos** em caso de comprometimento de confidencialidade, integridade ou disponibilidade.
- 4 **Atribuir classes** : pública, interna, confidencial ou restrita.
- 5 **Rotular e registrar** os ativos em inventário, vinculando cada classe a um conjunto mínimo de controles.

Referências: Fips 199 e Nist SP 800-60 (níveis de impacto baixo/moderado/alto); Nist CSF 2.0, função Identify; ISO/IEC 27002 (controles de inventário e rotulagem).

ATIVOS DE ALTO VALOR

Informações ou sistemas tão críticos que sua perda, degradação ou indisponibilidade teria **impacto severo** na missão ou na segurança da empresa (Cisa — Securing High Value Assets). Identificá-los orienta prioridades de proteção, planos de resposta a incidentes, alocação de recursos e critérios de auditoria.

A auditoria interna é definida pelo IIA como atividade independente e objetiva de avaliação e consultoria, destinada a agregar valor e melhorar as operações. A auditoria de gestão em TI aplica esses princípios para verificar se a TI está alinhada à estratégia, se riscos são tratados adequadamente e se a governança contribui para a geração de valor.

Escopo baseado em riscos

O plano de auditoria (IPPF Standards) considera objetivos estratégicos, principais riscos e maturidade da governança — no contexto de TI, isso inclui a natureza dos sistemas (críticos, suporte, periféricos) e a exposição a riscos cibernéticos, de privacidade e de conformidade.

Execução e evidências

O Itaf exige independência, objetividade, garantia razoável (reasonable assurance) e devido zelo profissional. Evidência suficiente, apropriada e relevante vem de entrevistas, inspeções, observação direta, testes de controle e revisão documental.

Ceticismo profissional

Em todas as etapas, o auditor avalia a confiabilidade das informações e a consistência das evidências — o trabalho deve ser documentado de forma clara e rastreável, permitindo revisão independente.

Opinião global – a escala de conclusão

Satisfatória alta	Controles eficazes e riscos bem gerenciados.
Satisfatória baixa	Controles em geral adequados, mas com fragilidades pontuais.
Insatisfatória	Oportunidades de melhoria materiais e riscos relevantes não tratados.

Os critérios de auditoria (referenciais usados para avaliar a entidade) devem ser objetivos, mensuráveis, completos e relevantes.

03

Ética e resolução de dilemas éticos em auditoria

A credibilidade da auditoria está diretamente ligada a uma base ética sólida. O código do Iesba/Ifac estabelece 5 princípios fundamentais, convergentes com os códigos de ética do IIA e da Isaca.

Integridade

Agir com honestidade e retidão, mesmo sob pressão.

Objetividade

Evitar vieses, conflitos de interesse e influências indevidas.

Competência e zelo profissional

Manter conhecimentos atualizados e executar as atividades com diligência.

Confidencialidade

Proteger as informações obtidas, salvo obrigação legal ou profissional de revelação.

Comportamento profissional

Atuar em conformidade com leis, regulamentos e normas da profissão.

As 5 ameaças à observância dos princípios (Iesba)

AMEAÇA	QUANDO OCORRE
Interesse próprio	Benefícios financeiros ou pessoais podem influenciar o julgamento profissional.
Auto-revisão	O profissional é chamado a revisar um trabalho que ele próprio realizou.
Advocacia	O auditor passa a defender excessivamente os interesses do cliente ou da empresa.
Familiaridade	Relações pessoais/profissionais próximas geram complacência ou falta de ceticismo.
Intimidação	Pressões reais ou percebidas, inclusive de superiores hierárquicos.

QUANDO A AMEAÇA NÃO PODE SER REDUZIDA

Se as medidas de proteção não forem capazes de reduzir a ameaça a um nível aceitável, o auditor deve considerar **recusar o trabalho, relatar a situação a instâncias apropriadas ou desligar-se da função** (IIA; Isaca).

Metodologia para resolução de dilemas éticos

- 1 **Identificar** o dilema, o princípio potencialmente violado e as partes envolvidas.
- 2 **Avaliar a significância** da ameaça: probabilidade de comprometimento do julgamento e impacto potencial.
- 3 **Adotar medidas de proteção** : revisão independente, reatribuição de responsabilidades, rotação de equipe ou limitação de escopo — sempre documentadas.
- 4 **Consultar e escalar** , se o dilema persistir: superiores, comitês de ética, jurídico, conselhos profissionais, reguladores, comitê de auditoria ou conselho de administração.
- 5 **Documentar** o dilema, as alternativas, as medidas adotadas e a decisão tomada — considerando não aceitar ou interromper o trabalho se nenhuma medida reduzir a ameaça a um nível aceitável.

04

Comunicação eficaz: relatórios e apresentação de resultados

As normas do IIA exigem que as comunicações de auditoria sejam precisas, objetivas, claras, concisas, construtivas, completas e oportunas.

Um relatório de auditoria de gestão em TI costuma conter: objetivo, escopo e metodologia; contexto e critérios utilizados (Cobit 2019, publicações Nist, ISO/IEC 27002, ISO/IEC 38500, políticas internas); e um **resumo executivo** com as principais

conclusões, a opinião global, os riscos relevantes e as recomendações priorizadas. Os achados costumam seguir uma estrutura fixa: **condição observada** → **critério aplicável** → **causa provável** → **efeito/risco associado** → **recomendação**.

Plano de ação e acompanhamento

Recomendações práticas e proporcionais aos riscos; o relatório registra medidas corretivas, responsáveis, prazos e indicadores. Mecanismos formais de follow-up garantem que melhorem de fato a governança.

Resultados técnicos para gestores

Vulnerabilidades e falhas técnicas precisam virar linguagem de negócio: impacto (financeiro, operacional, legal, reputacional), grau de exposição (alto/médio/baixo) e prioridade — com jargão moderado e recursos visuais (dashboards, mapas de calor).

Comunicação de riscos de TI

Deve estar integrada ao ERM corporativo. A Nistir 8286 propõe registros e agregação de riscos de TI; o Nist CSF 2.0 sugere perfis de risco alinhados às 6 funções (govern, identify, protect, detect, respond, recover).



Termos-chave

Vocabulário que costuma aparecer em questões de múltipla escolha.

Egit

Enterprise governance of information and technology — governança de TI integrada à governança corporativa.

Ativo de alto valor

Informação/sistema cuja perda teria impacto severo na missão da empresa.

IPPF

International Professional Practices Framework — normas internacionais de auditoria interna (IIA).

Garantia razoável

Reasonable assurance — nível de confiança que a evidência de auditoria proporciona, exigido pelo Itaf.

Ceticismo profissional

Postura de questionar e avaliar criticamente a confiabilidade das evidências.

Opinião global

Conclusão geral sobre o objeto auditado, baseada em evidências, critérios e riscos.

Iesba

International Ethics Standards Board for Accountants — define os 5 princípios éticos fundamentais.

Yellow Book

Referencial de auditoria governamental dos EUA, citado quanto a mecanismos de acompanhamento.

ERM

Enterprise risk management — gestão integrada de riscos corporativos, à qual a comunicação de riscos de TI deve se conectar.

Perfil de risco

Representação estruturada dos riscos de uma organização, usada pelo Nist CSF 2.0 para comunicação à alta gestão.



Revisão rápida antes da prova

Confira se você consegue responder a cada ponto sem consultar o texto.

- ☐ Explicar o que é Egit e diferenciar o papel do conselho/alta gestão do papel da gestão de TI.
- ☐ Descrever as 5 etapas do processo de classificação de ativos de informação.
- ☐ Explicar o que caracteriza um "ativo de alto valor" e por que ele importa para a auditoria.
- ☐ Explicar por que o plano de auditoria de TI deve ser baseado em riscos (IPPF).
- ☐ Diferenciar as 3 faixas da escala de opinião global (satisfatória alta, satisfatória baixa, insatisfatória).
- ☐ Listar os 5 princípios éticos do Iesba e dar um exemplo prático de cada um.
- ☐ Diferenciar as 5 ameaças éticas: interesse próprio, auto-revisão, advocacia, familiaridade e intimidação.
- ☐ Descrever os passos da metodologia de resolução de dilemas éticos.

- ☐ Explicar a estrutura de um achado de auditoria: condição, critério, causa, efeito, recomendação.
- ☐ Explicar como a comunicação de riscos de TI deve se conectar ao ERM corporativo.



Referências do capítulo

ABNT. NBR ISO/IEC 27002:2022; NBR ISO/IEC 38500:2025; NBR ISO 31000:2018.

BRASIL. Tribunal de Contas da União (TCU). Referencial básico de governança organizacional, 3. ed., 2020; Referencial básico de gestão de riscos, 2018.

Cisa. Securing High Value Assets, 2018.

Iesba. Handbook of the international code of ethics for professional accountants, 2024.

IIA — Institute of Internal Auditors. IPPF — Practice guide: formulating and expressing internal audit opinions; Audit reports: communicating assurance engagement results, 2016; código de ética, 2009.

Intosai. ISSAI 100 — fundamental principles of public-sector auditing, 2019.

Isaca. Cobit 2019 Framework, 2018; IT Audit Framework (Itaf), 4. ed., 2020.

Nist. Fips PUB 199 (2004); SP 800-60 (categorização de informação); Nistir 8286 — integração ERM (2020); Cybersecurity Framework (CSF) 2.0, 2024.

OECD. G20/OECD principles of corporate governance 2023.

United States. Yellow Book, 2018.

Resumo gerado a partir do capítulo "Auditoria de gestão, governança de TI, ética e comunicação" (SEG_AUD_SIS_08_ACE_2025) para revisão de prova.